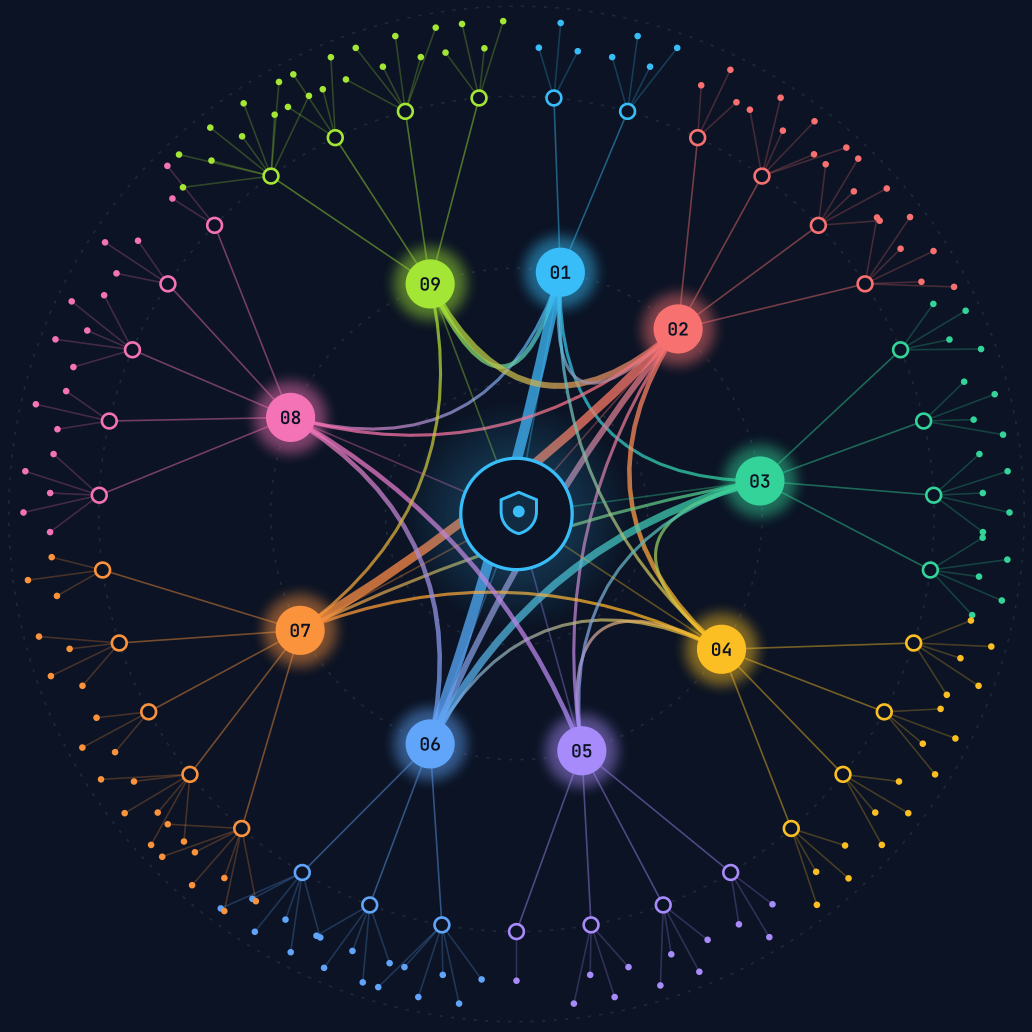
Universidad de la Sierra Sur
Licenciatura en Informática

MAPA VISUAL · PRIMER PARCIAL

Glosario de terminología y temas

Seguridad de Centros de Informática

ALUMNO	Daniel González Ruiz
DOCENTE	Dr. Arisaí Darío Barragán López
GRUPO	906
CICLO	Ciclo Escolar 26-27A
ENTREGA	23 de octubre de 2026



9 temas
155 términos
42 relaciones

Cada tema es una rama del mapa; sus subtemas agrupan los términos y las líneas de colores conectan conceptos de distintos temas. Versión interactiva en 3D: glosario-beryl.vercel.app

VISTA GENERAL

Mapa de temas del primer parcial

Del centro salen los 9 temas; cada tema se divide en subtemas y las bandas internas muestran qué temas comparten conceptos.



01 **Objetivos principales de la seguridad** p. 3
Lo que toda medida de seguridad busca proteger · 7 términos
02 03 04 06 08 09

02 **Conceptos básicos de seguridad** p. 4
El vocabulario base del riesgo y los ataques · 20 términos
01 04 05 06 07 08 09

03 **Controles de seguridad y de acceso** p. 5
Las medidas que reducen el riesgo · 18 términos
01 04 05 06 07

04 **Políticas de seguridad** p. 6
Las reglas de la organización y de su personal · 17 términos
01 02 03 05 06 07

05 **Marcos, estándares y normativas** p. 7
Referencias externas para organizar la seguridad · 12 términos
02 03 04 08

06 **Soluciones tecnológicas de ciberseguridad** p. 8
Herramientas que ponen en práctica los controles · 17 términos
01 02 03 04 08

07 **Análisis y gestión de riesgos** p. 9
Medir, priorizar y decidir qué hacer con cada riesgo · 23 términos
02 03 04 09

08 **Prevención de pérdida de datos (DLP)** p. 10
Evitar que la información sensible salga de donde debe estar · 1…
01 02 05 06

09 **Continuidad del negocio y recuperación (BCP / DRP)** p. 11
Seguir operando y recuperarse tras un desastre · 23 términos
01 02 07

Tema → subtema

Conceptos compartidos (más grueso = más relaciones)

00 Tema relacionado

01 Objetivos principales de la seguridad

Lo que toda medida de seguridad busca proteger

7 términos · 2 subtemas
12 relaciones con 02 03 04 06 08 09

Objetivos principales de la seguridad

TRÍADA CIA

Confidencialidad
Solo las personas autorizadas pueden ver la información; se protege con cifrado y control de acceso.
06 Cifrado · 08 DLP · 04 Acuerdo de confidencialidad

Integridad
La información se mantiene exacta y completa; nadie la modifica sin permiso o sin dejar rastro.
06 Función hash · 06 Firma digital

Disponibilidad
Los sistemas y datos están accesibles y funcionando cuando los usuarios autorizados los necesitan.
09 BCP · 09 Alta disponibilidad · 02 DoS / DDoS

COMPLEMENTOS (AAA Y NO REPUDIO)

Autenticación
Comprobar que alguien es quien dice ser mediante contraseña, token, tarjeta o biometría.
06 MFA

Autorización
Definir qué puede hacer un usuario ya autenticado y a qué recursos tiene acceso.
03 RBAC

Contabilidad (auditoría)
Registrar quién hizo qué y cuándo para poder revisar y rastrear las acciones.
06 SIEM

No repudio
Garantía de que el autor de una acción o mensaje no puede negar haberlo realizado.
06 Firma digital

02 Conceptos básicos de seguridad

El vocabulario base del riesgo y los ataques

20 términos · 4 subtemas
16 relaciones con 01 04 05 06 07 08 09

Conceptos básicos de seguridad

FUNDAMENTOS

Seguridad de la información
Proteger la información, en cualquier formato, contra acceso, uso, cambio o destrucción no autorizados.

Ciberseguridad
Parte de la seguridad enfocada en defender sistemas, redes y datos digitales contra ataques.

Activo
Cualquier recurso valioso para la organización: datos, equipos, software, personas o reputación.
07 AV · 09 Inventario de activos

ELEMENTOS DEL RIESGO

Amenaza
Cualquier evento, persona o situación que podría causar daño a un activo.
07 Evaluación de riesgos

Vulnerabilidad
Debilidad en un sistema, proceso o persona que una amenaza puede aprovechar.
07 Escaneo de vulnerabilidades
06 Gestión de parches

Riesgo
Posibilidad de que una amenaza aproveche una vulnerabilidad y cause un daño.

```
Riesgo = Probabilidad × Impacto
```

07 Gestión de riesgos

Impacto
Daño o consecuencia que sufre la organización cuando un riesgo se materializa.

Exploit
Código o técnica que aprovecha una vulnerabilidad específica para atacar un sistema.
07 Prueba de penetración

Incidente de seguridad
Evento que compromete la confidencialidad, integridad o disponibilidad de la información.
09 IMP

ACTORES Y VECTORES

Actor de amenaza
Quien origina el ataque: hacker, empleado, hacktivista, crimen organizado o un Estado.

Amenaza interna (insider)
Riesgo causado por personas con acceso legítimo, ya sea por descuido o con mala intención.
08 Exfiltración

Vector de ataque
Camino o medio que usa el atacante para entrar: correo, USB, red o sitio web.

Superficie de ataque
Conjunto de todos los puntos por donde un sistema podría ser atacado.

APT
Amenaza persistente avanzada: atacante con muchos recursos que permanece oculto largo tiempo en la red.

ATAQUES COMUNES

Malware
Software malicioso hecho para dañar, espiar o tomar el control de un equipo.
05 NIST SP 800-83
06 Antivirus / antimalware

Ransomware
Malware que cifra los archivos de la víctima y pide un rescate para liberarlos.
09 Respaldo

Ingeniería social
Manipular a las personas para que revelen información o hagan algo inseguro.
04 Concientización

Phishing
Correo o mensaje falso que se hace pasar por alguien confiable para robar datos o contraseñas.
04 Concientización

Día cero (zero-day)
Vulnerabilidad que el fabricante aún no conoce ni ha corregido, pero ya puede explotarse.
06 Gestión de parches

DoS / DDoS
Ataque que satura un servicio con tráfico para que deje de estar disponible.
01 Disponibilidad

03 Controles de seguridad y de acceso

Las medidas que reducen el riesgo

18 términos · 4 subtemas
8 relaciones con 01 04 05 06 07

Controles de seguridad y de acceso

PRINCIPIOS

Control (contramedida)
Medida que reduce un riesgo evitando, detectando o corrigiendo un problema.
07 Mitigar · 05 NIST SP 800-53

Defensa en profundidad
Usar varias capas de protección para que, si una falla, otra siga protegiendo.

Privilegio mínimo
Dar a cada usuario solo los permisos indispensables para hacer su trabajo.

Confianza cero (zero trust)
No confiar en nadie por defecto: verificar cada acceso, venga de dentro o fuera de la red.
06 IAM

POR SU NATURALEZA

Administrativo (gerencial)
Se basa en políticas, procesos y gestión, como reglas, capacitación y análisis de riesgos.
04 Política de seguridad

Técnico (lógico)
Se implementa con tecnología, como firewall, cifrado, antivirus o contraseñas.
06 Firewall

Operativo
Lo realizan personas en el día a día: guardias, respaldos y revisión de bitácoras.

Físico
Protege instalaciones y equipos con cerraduras, cámaras, credenciales y rejas.

POR SU FUNCIÓN

Preventivo
Busca impedir que el incidente ocurra, como un firewall o una cerradura.

Detectivo
Descubre un incidente mientras ocurre o después, como un IDS o una cámara.
06 IDS

Correctivo
Reduce el daño y restablece el sistema después del incidente, como restaurar un respaldo.

Disuasivo
Desanima al atacante antes de intentarlo, como letreros o vigilancia visible.

Compensatorio
Alternativa que se usa cuando el control principal no se puede aplicar.

MODELOS DE CONTROL DE ACCESO

DAC
Control discrecional: el dueño del recurso decide quién puede usarlo, como los permisos de archivos.

MAC
Control obligatorio: el sistema da acceso según etiquetas de clasificación como confidencial o secreto.

RBAC
Control basado en roles: los permisos se asignan al puesto y no a la persona.
01 Autorización · 06 IAM

ABAC
Control basado en atributos: decide según datos del usuario, del recurso, la hora o la ubicación.

Basado en reglas
El acceso depende de reglas generales del sistema, como horarios o listas del firewall.

04 Políticas de seguridad

Las reglas de la organización y de su personal

17 términos · 4 subtemas
7 relaciones con 01 02 03 05 06 07

§ Políticas de seguridad

JERARQUÍA DOCUMENTAL

Política de seguridad
Documento de alto nivel, aprobado por la dirección, que define qué se protege y por qué.
03 Administrativo

Estándar
Regla obligatoria y específica para cumplir una política, por ejemplo la longitud mínima de contraseña.

Procedimiento
Pasos detallados y en orden para realizar una tarea de seguridad.

Guía (lineamiento)
Recomendación no obligatoria que orienta sobre la mejor forma de actuar.

Línea base (baseline)
Configuración mínima de seguridad que todos los sistemas deben cumplir.

POLÍTICAS COMUNES

Uso aceptable (AUP)
Reglas sobre lo que el usuario puede y no puede hacer con los recursos de la empresa.

Política de contraseñas
Define la complejidad, vigencia y manejo correcto de las contraseñas.
06 MFA

Escritorio limpio
No dejar documentos ni sesiones abiertas a la vista al retirarse del lugar de trabajo.

Acuerdo de confidencialidad (NDA)
Contrato en el que una persona se compromete a no revelar información de la empresa.
01 Confidencialidad

CONTROLES DE PERSONAL

Separación de funciones
Dividir una tarea crítica entre varias personas para que nadie pueda cometer fraude solo.

Rotación de puestos
Cambiar periódicamente al personal de puesto para detectar abusos y evitar depender de alguien.

Vacaciones obligatorias
Obligar al empleado a ausentarse para que otro revise su trabajo y detecte irregularidades.

Concientización
Capacitar a los usuarios para reconocer amenazas como el phishing y actuar de forma segura.
02 Ingeniería social 02 Phishing

GOBIERNO Y CUMPLIMIENTO

GRC
Gobierno, riesgo y cumplimiento: alinear la seguridad con los objetivos, riesgos y leyes del negocio.
07 Gestión de riesgos

Cumplimiento (compliance)
Demostrar que la organización respeta leyes, normas y políticas internas.
05 GDPR

Debida diligencia
Investigar y conocer los riesgos antes de tomar una decisión.

Debido cuidado
Actuar con responsabilidad para proteger los activos una vez que se conocen los riesgos.

05 Marcos, estándares y normativas

Referencias externas para organizar la seguridad

12 términos · 4 subtemas
5 relaciones con 02 03 04 08

Marcos, estándares y normativas

NORMAS ISO

ISO/IEC 27001
Norma internacional certificable para crear y mantener un sistema de gestión de seguridad de la información.

ISO/IEC 27002
Guía de buenas prácticas que describe los controles de seguridad que apoyan a la ISO 27001.

SGSI
Sistema de gestión de seguridad de la información: ciclo continuo para manejar los riesgos de la información.

NIST Y CIS

NIST CSF
Marco de ciberseguridad organizado en cinco funciones para gestionar riesgos.

`Identificar → Proteger → Detectar → Responder → Recuperar`

NIST SP 800-53
Catálogo amplio de controles de seguridad y privacidad para sistemas de información.

03 Control

NIST SP 800-83
Guía para prevenir y atender incidentes de malware en equipos de escritorio y laptops.

02 Malware

CIS Controls
Lista de 18 controles prácticos y priorizados para defenderse de los ataques más comunes.

LEYES Y REGULACIONES

GDPR (RGPD)
Reglamento europeo que protege los datos personales y da derechos a sus dueños.

04 Cumplimiento 08 PII

PCI DSS
Estándar obligatorio para quien procesa, guarda o transmite datos de tarjetas de pago.

HIPAA
Ley de Estados Unidos que protege la información médica de los pacientes.

CCPA
Ley de privacidad de California que da al consumidor control sobre sus datos personales.

GOBIERNO DE DATOS

DAMA-DMBOK
Guía de buenas prácticas para la gestión y el gobierno de los datos.

08 Clasificación de datos

06 Soluciones tecnológicas de ciberseguridad

Herramientas que ponen en práctica los controles

17 términos · 3 subtemas
16 relaciones con 01 02 03 04 08

Soluciones tecnológicas de ciberseguridad

RED Y PERÍMETRO

Firewall
Filtra el tráfico entre redes y bloquea lo que no cumple las reglas definidas.
03 Técnico

IDS
Sistema de detección de intrusos: vigila el tráfico y avisa ante actividad sospechosa.
03 Detectivo

IPS
Sistema de prevención de intrusos: detecta el ataque y además lo bloquea automáticamente.

VPN
Túnel cifrado para conectarse de forma segura a una red a través de Internet.
08 Datos en tránsito

Segmentación de red
Dividir la red en zonas separadas, como VLAN o DMZ, para contener los ataques.

NAC
Control de acceso a la red: solo deja conectarse a equipos que cumplen las políticas.

MONITOREO Y ENDPOINT

SIEM
Reúne y correlaciona bitácoras de muchos sistemas para detectar incidentes en tiempo real.
01 Contabilidad

SOC
Centro de operaciones de seguridad: equipo que vigila y responde a incidentes de forma continua.

Antivirus / antimalware
Software que detecta, bloquea y elimina programas maliciosos en el equipo.
02 Malware

EDR
Herramienta que registra la actividad de cada equipo y responde automáticamente ante amenazas.

Gestión de parches
Instalar actualizaciones a tiempo para cerrar vulnerabilidades conocidas.
02 Día cero 02 Vulnerabilidad

IDENTIDAD Y CRIPTOGRAFÍA

IAM
Gestión de identidades y accesos: administra cuentas, roles y permisos de los usuarios.
03 Confianza cero 03 RBAC

MFA
Autenticación multifactor: pide dos o más pruebas, como contraseña y un código en el celular.
01 Autenticación 04 Política de contraseñas

Cifrado
Convierte datos legibles en ilegibles con una clave, para que solo el autorizado pueda leerlos.
01 Confidencialidad

Función hash
Genera una huella única de los datos; si cambian aunque sea un poco, cambia el hash.
01 Integridad 08 Huella digital de datos

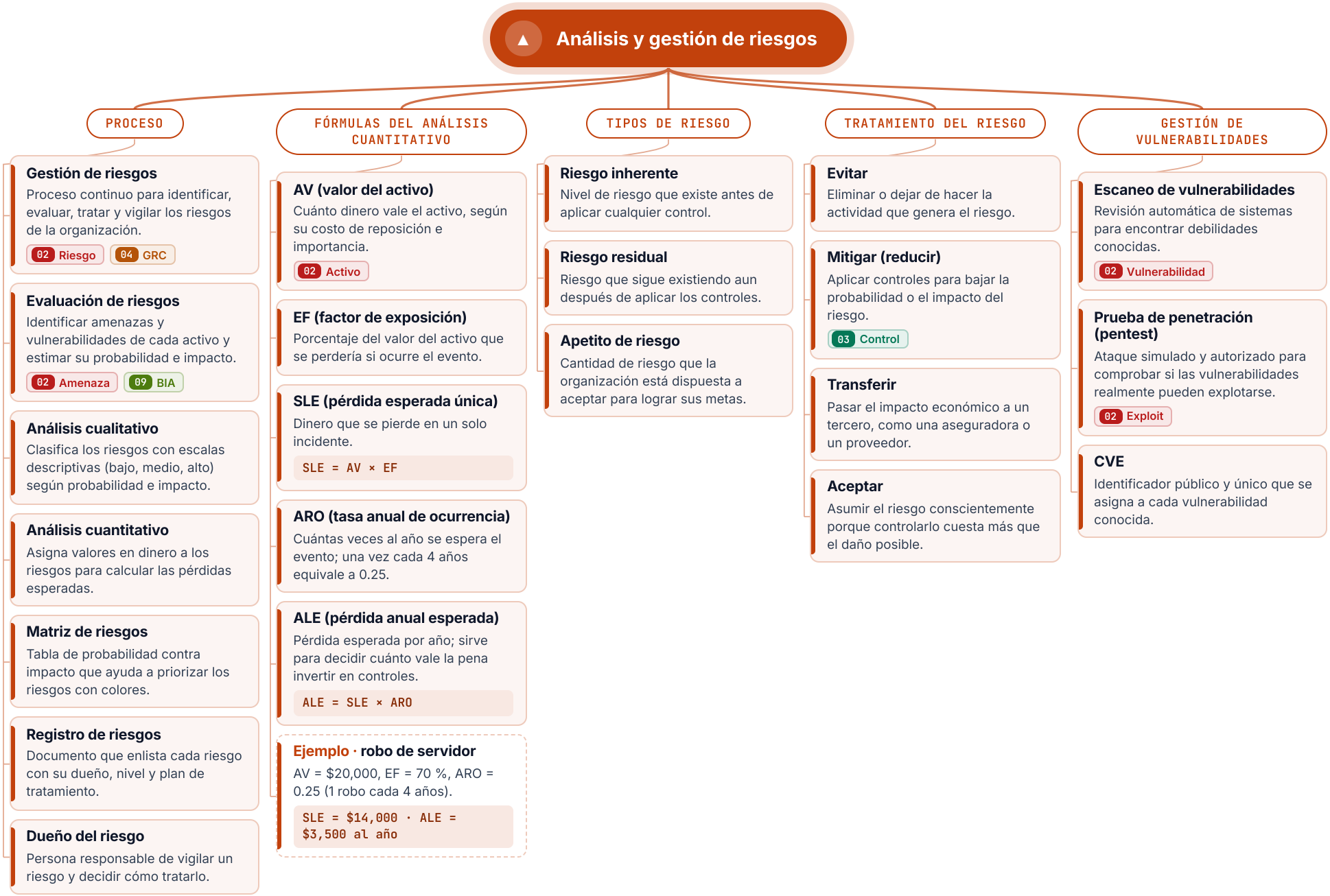
Firma digital
Usa criptografía para probar quién envió un mensaje y que no fue alterado.
01 Integridad 01 No repudio

Certificado digital (PKI)
Documento electrónico, emitido por una autoridad confiable, que une una llave pública con su dueño.

07 Análisis y gestión de riesgos

Medir, priorizar y decidir qué hacer con cada riesgo

23 términos · 5 subtemas
8 relaciones con 02 03 04 09



08 Prevención de pérdida de datos (DLP)

Evitar que la información sensible salga de donde debe estar

18 términos · 5 subtemas
6 relaciones con 01 02 05 06



09 Continuidad del negocio y recuperación (BCP / DRP)

Seguir operando y recuperarse tras un desastre

23 términos · 4 subtemas
6 relaciones con 01 02 07



PLANES

BCP
Plan de continuidad del negocio: mantiene las operaciones esenciales de toda la empresa durante una crisis.
01 Disponibilidad

DRP
Plan de recuperación ante desastres: restaura los sistemas de TI y los datos; forma parte del BCP.

BCDR
Gestión conjunta de la continuidad del negocio y la recuperación ante desastres.

BIA
Análisis de impacto al negocio: identifica procesos críticos y el daño de detenerlos; es el punto de partida.
07 Evaluación de riesgos

IMP
Plan de gestión de incidentes: atiende un incidente de seguridad antes de que se convierta en crisis.
02 Incidente de seguridad

BRP
Plan de reanudación del negocio: cómo retomar las operaciones comerciales y la cadena de suministro.

COOP
Plan de continuidad de operaciones: sostiene las funciones esenciales durante interrupciones largas.

OEP
Plan de emergencia para ocupantes: protege a empleados y visitantes, por ejemplo con evacuaciones.

Plan de comunicación
Define cómo informar a empleados, clientes, proveedores y medios durante una crisis.

MÉTRICAS

RTO
Tiempo objetivo de recuperación: tiempo máximo que un proceso puede estar detenido.

RPO
Punto objetivo de recuperación: cantidad máxima de datos, medida en tiempo, que se puede perder.

MTBF
Tiempo medio entre fallas: cuánto funciona un equipo, en promedio, antes de fallar.

MTTR
Tiempo medio de reparación: cuánto tarda, en promedio, un equipo en volver a funcionar.

ESTRATEGIAS DE RECUPERACIÓN

Respaldo (backup)
Copia periódica de los datos guardada en otro lugar para poder restaurarlos.
02 Ransomware

Sitio caliente
Instalación alterna equipada y lista para operar casi de inmediato; es la más costosa.

Sitio tibio
Instalación con parte del equipo; necesita algo de tiempo para empezar a operar.

Sitio frío
Espacio con energía y conexión básicas, pero sin equipos; es el más lento y barato.

Alta disponibilidad
Duplicar componentes para que el servicio siga funcionando aunque uno falle.
01 Disponibilidad

Recuperación virtualizada
Usar máquinas virtuales que arrancan en minutos para recuperar aplicaciones críticas.

GESTIÓN DEL PLAN

Inventario de activos
Lista de activos clasificados como críticos, importantes o sin importancia para la operación.
02 Activo

Roles del plan
Informante de incidentes, supervisor del DRP y gestor de activos coordinan la respuesta.

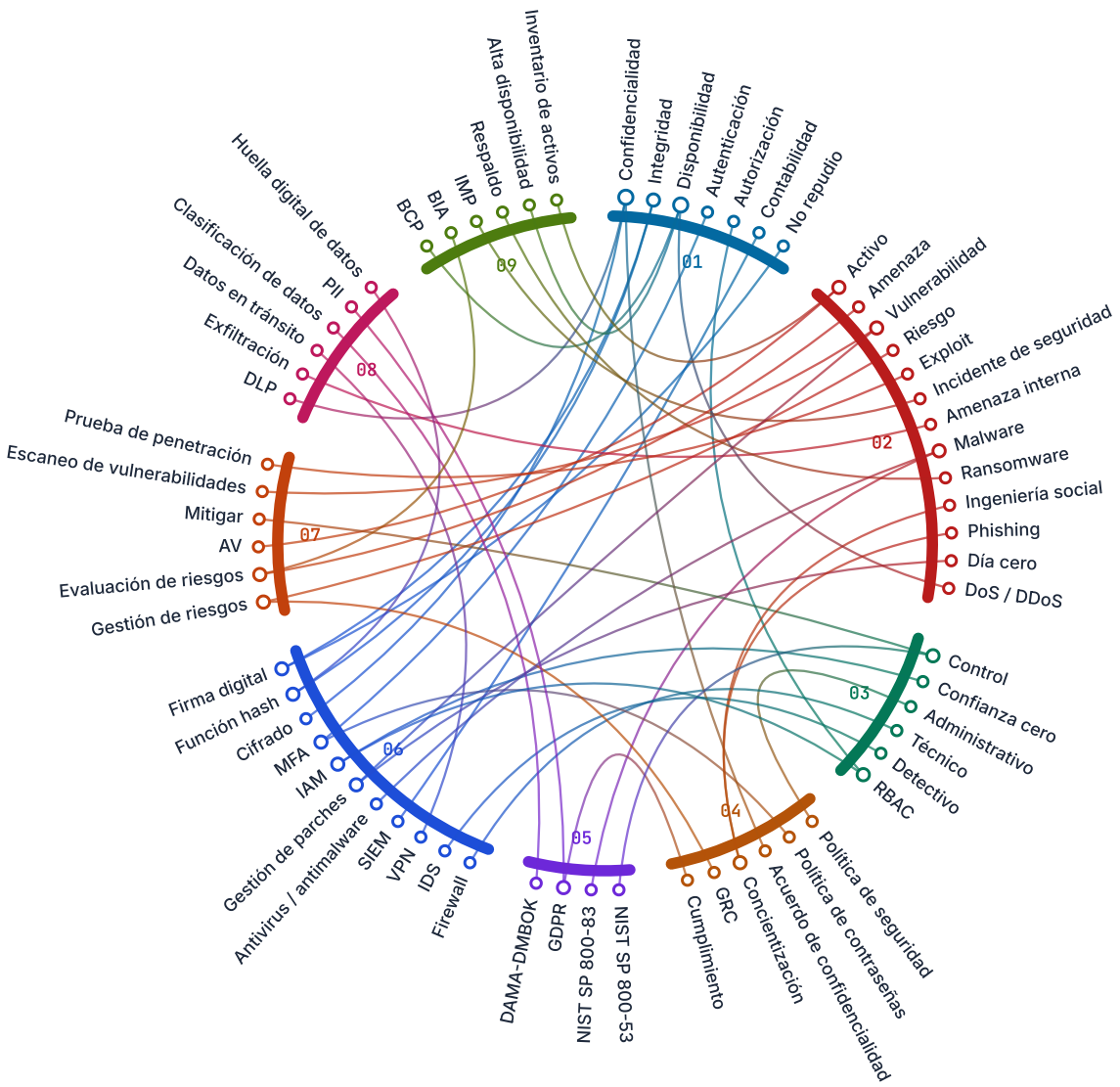
Pruebas y simulacros
Ensayos periódicos que confirman que el plan funciona y que el personal sabe qué hacer.

Resiliencia
Capacidad de la empresa para adaptarse y seguir operando ante cualquier adversidad.

CONEXIONES

Red de relaciones entre términos

Los 65 términos que se conectan con otros, agrupados por tema alrededor del círculo.



Cómo leerla

Cada punto es un término y cada línea une dos conceptos relacionados. El color de la línea va del tema de un término al del otro; el tamaño del punto crece con su número de conexiones.

Las líneas que cruzan el centro muestran cómo un tema se apoya en otro; por ejemplo, la confidencialidad se garantiza con cifrado y DLP.

Términos más conectados

Confidencialidad	3 · 01
Disponibilidad	3 · 01
Integridad	2 · 01
Activo	2 · 02
Vulnerabilidad	2 · 02
Malware	2 · 02
Control (contramedida)	2 · 03
RBAC	2 · 03

REFERENCIA RÁPIDA

Índice alfabético

El número de color indica el tema; cada tema empieza en la página 3 (tema 01) y sigue en orden.

A

- ABAC 03
- Aceptar 07
- Activo 02
- Actor de amenaza 02
- Acuerdo de confidencialidad (NDA) 04
- Administrativo (gerencial) 03
- ALE (pérdida anual esperada) 07
- Alta disponibilidad 09
- Amenaza 02
- Amenaza interna (insider) 02
- Análisis cualitativo 07
- Análisis cuantitativo 07
- Antivirus / antimalware 06
- Apetito de riesgo 07
- APT 02
- ARO (tasa anual de ocurrencia) 07
- Autenticación 01
- Autorización 01
- AV (valor del activo) 07

B

- Basado en reglas 03
- BCDR 09
- BCP 09
- BIA 09
- BRP 09

C

- CCPA 05
- Certificado digital (PKI) 06
- Ciberseguridad 02
- Cifrado 06
- CIS Controls 05
- Clasificación de datos 08
- Coincidencia de patrones 08
- Compensatorio 03
- Concientización 04
- Confianza cero (zero trust) 03
- Confidencialidad 01
- Contabilidad (auditoría) 01
- Control (contramedida) 03
- COOP 09
- Correctivo 03
- Cumplimiento (compliance) 04
- CVE 07

D

- DAC 03
- DAMA-DMBOK 05
- Datos en reposo 08
- Datos en tránsito 08
- Datos en uso 08
- Debida diligencia 04
- Debido cuidado 04
- Defensa en profundidad 03
- Detectivo 03
- Día cero (zero-day) 02
- Disponibilidad 01
- Disuasivo 03
- DLP 08
- DLP de endpoint 08
- DLP de red 08
- DLP en la nube 08
- DoS / DDoS 02
- DRP 09
- Dueño del riesgo 07

E

- EDR 06
- EF (factor de exposición) 07
- Ejemplo: robo de servidor 07
- Escaneo de vulnerabilidades 07
- Escritorio limpio 04
- Estándar 04
- Estructurados / no estructurados 08
- Evaluación de riesgos 07
- Evitar 07
- Exfiltración 08
- Exploit 02

F

- Filtración (data breach) 08
- Firewall 06
- Firma digital 06
- Físico 03
- Fuga de datos (data leak) 08
- Función hash 06

G

- GDPR (RGPD) 05
- Gestión de parches 06
- Gestión de riesgos 07
- GRC 04
- Guía (lineamiento) 04

H

- HIPAA 05
- Huella digital de datos 08

I

- IAM 06
- IDS 06
- IMP 09
- Impacto 02
- Incidente de seguridad 02
- Ingeniería social 02
- Integridad 01
- Inventario de activos 09
- IPS 06
- ISO/IEC 27001 05
- ISO/IEC 27002 05

L

- Línea base (baseline) 04

M

- MAC 03
- Malware 02
- Matriz de riesgos 07
- MFA 06
- Mitigar (reducir) 07
- MTBF 09
- MTTR 09

N

- NAC 06
- NIST CSF 05
- NIST SP 800-53 05
- NIST SP 800-83 05
- No repudio 01

O

- OEP 09
- Operativo 03

P

- PCI DSS 05
- Phishing 02
- PII 08
- Plan de comunicación 09
- Política de contraseñas 04
- Política de seguridad 04
- Preventivo 03
- Privilegio mínimo 03
- Procedimiento 04
- Proceso DLP 08
- Propiedad intelectual 08
- Prueba de penetración (pentest) 07
- Pruebas y simulacros 09

R

- Ransomware 02
- RBAC 03
- Recuperación virtualizada 09
- Registro de riesgos 07
- Resiliencia 09
- Respaldo (backup) 09
- Riesgo 02
- Riesgo inherente 07
- Riesgo residual 07
- Roles del plan 09
- Rotación de puestos 04
- RPO 09
- RTO 09

S

- Segmentación de red 06
- Seguridad de la información 02
- Separación de funciones 04
- SGSI 05
- Shadow data / shadow IT 08
- SIEM 06
- Sitio caliente 09
- Sitio frío 09
- Sitio tibio 09
- SLE (pérdida esperada única) 07
- SOC 06
- Superficie de ataque 02

T

- Técnico (lógico) 03
- Transferir 07

U

- Uso aceptable (AUP) 04

V

- Vacaciones obligatorias 04
- Vector de ataque 02
- VPN 06
- Vulnerabilidad 02